

CYBERCRIME PSYCHOLOGY ANALYSIS

EXECUTIVE SUMMARY:

This report covers the analysis of 5 landmark cybercrime breaches: **MGM Resorts (2023)**, **RSA Security (2011)**, the **Hong Kong Deepfake Scam (2024)**, the **Twitter "VIP" Hack (2020)**, and the **Uber MFA Breach (2022)**.

Despite the fact that these organizations had high leading technical defenses, they still fell victim of these attacks. The attackers didn't use codes to get pass their defenses but they manipulated the human psychology. This study shifts the focus from "hacking code" to "hacking human behavior" – a concept we define as "THE HUMAN ZERO DAY".

They used things like fear, curiosity to get what they wanted in these cases.

Key Lessons Learned:

- Being too helpful is risky: In the MGM case, an IT guy just wanted to help a "struggling" worker, but he was actually helping a hacker.
- The "Boss" Factor: In the Hong Kong case, a worker saw their boss's face on a video call (Deepfake) and obeyed immediately without double-checking.
- The "Stress" Tactic: In the Uber case, the hacker just kept pestering the worker with alerts until the worker got tired and gave up.

Computers are hard to hack, but humans are easy. If we want to stay safe, we have to teach people that anyone can be a target and that they should always verify who they are talking to, even if it looks like their boss or a teammate.

CASE 1: THE MGM RESORT INCIDENT OVERVIEW (2023)

The attack was carried out by a group known as **Scattered Spider**. They did not use a "brute force" attack on a server; instead, they targeted the **IT Help Desk**. By gathering information from LinkedIn, they identified a legitimate employee and called the help desk pretending to be that person. They claimed to have lost access to their account and successfully convinced the technician to reset their credentials and Multi-Factor Authentication (MFA). With this the attackers were able to perform lateral movement across the organization's network and gained access to their main servers enabling them to encrypt data. This caused the organization massive financial loss and disruption in operations. There was also a heavy data theft and thereafter the organization's reputation was damaged.

WHAT MADE THE ATTACKER CREDIBLE? By using specific details found on LinkedIn (full name, job title, and department), the attacker created an "insider" persona. The help desk agent assumed that only a real colleague would have such specific information. They knew exactly which department to call and which identity management system (Okta) was being used, making their request for a "password reset" seemed like a routine and sounded legitimate.

WHAT MADE THE VICTIM COMPLY? Help desk staff are trained in customer service. Their psychological drive is to be helpful and reduce friction. The attacker exploited this professional desire to solve a "colleague's" problem quickly. The attacker also created a believable story (a frustrated employee unable to work). This triggered empathy in the victim, causing them to focus on the "problem" rather than the "security protocol."

CASE 2: RSA FAKE RECRUITMENT ATTACK (2011):

The hackers sent an email to a small group of RSA employees. The subject line was: **"2011 Recruitment Plan."** One staff member saw it in the junk folder, retrieved it and thought it was an important work file, then opened it. Inside the email was an Excel file. As soon as the staff clicked it, a hidden piece of malware took control of that person's computer. The hackers didn't stop at that one computer. They used that staff's account to move through the company's network until they found the **"Master Keys"** (the Seeds) for their security tokens.

The Master Keys were Stolen: RSA makes those "SecurID" tokens (the ones that show a 6-digit code for logging in). The hackers stole the secret formula used to create those codes. This caused a Global Panic and RSA had to spend about **\$66 million** to replace almost every single token they had ever sold to customers around the world.

WHAT MADE THE ATTACKER CREDIBLE?

The email used a subject line that sounded like a normal company routine word. It didn't look like a "You won \$1 million" scam. They sent it to a small group of people who actually deal with hiring or management and so because it fit their job description, they didn't doubt it.

People also trusted Excel (.xls) files as we use them every day for data. The attacker used a familiar tool to hide their intention.

WHY DID THE VICTIM COMPLY? Humans are naturally nosy about their workplace, and the attacker used that curiosity to make them click. When the email went to the Junk folder, the victim thought the computer had made a mistake and opened it anyway.

CASE 3: The HONG KONG \$25 MILLION DEEPFAKE SCAM (2024)

A worker in the finance department of a big multinational company in Hong Kong received an email that looked like it was from the company's **Chief Financial Officer (CFO)** based in the UK. The email said they needed to carry out a "secret transaction." The worker was suspicious at first. But then, he was invited to a **video conference call**. On the screen, he saw the CFO and several other staff members he recognized. Since he could "see" and "hear" his bosses telling

him what to do, he stopped doubting and followed their instructions. But, what he did not realize was that, the "bosses" on that video call were not real. The hackers used **Deepfake technology** (AI) to recreate the faces and voices of the company's executives using old videos of them found online.

The worker ended up making **15 transfers** to 5 different bank accounts, totaling **\$25 million (about 37 Billion Naira)**.

WHAT MADE THE ATTACKER CREDIBLE? We have a saying: "Seeing is believing." By showing a live video of the CFO's face, the attackers bypassed the worker's logic. Even if the request was "weird," the face was "real." Also, the hackers didn't just show one boss; they showed a whole room of colleagues and when you see a group of people agreeing on something, you are much more likely to follow along. This is called "**Social Proof**."

WHY DID THE VICTIM COMPLY? In a big company, when the big boss tells you to do something "now," you don't ask too many questions. The fear of being seen as difficult makes people obey. The hackers did something else: By telling the worker the transaction was "secret" and "confidential," the attackers gave the worker a reason why nobody else in the office knew about it.

CASE 4: THE TWITTER "VIP" HIJACK (2020)

The hackers called up Twitter employees on their personal phones. They pretended to be from the company's own internal **IT Help Desk**. They told the workers that there was a glitch with the company's VPN (the network everyone uses to work from home) and that they needed to "verify" their login details to fix it. The workers trusted the caller because the hackers spoke exactly like Twitter employees. The workers went to a fake website the hackers gave them, which looked exactly like the real Twitter staff login page, and typed in their usernames and passwords. Once the hackers got those logins, they used them to open a secret internal tool that Twitter staff use to manage accounts. This tool enabled them to bypass any password and post tweets from *any* account in the world.

The hackers took over the accounts of **Elon Musk, Barack Obama, Bill Gates, and Apple**. They posted a scam saying: "*Send me Bitcoin, and I will double it.*" Within a few hours, regular people fell for it and sent over **\$117,000** to the hackers before Twitter could shut it down.

WHAT MADE THE ATTACKER CREDIBLE? The hackers spent time researching Twitter first. They knew the names of internal tools, they knew how the IT team talked, and they knew the company was having real VPN issues. Because they had information about what was going on inside, they didn't sound like strangers. By presenting themselves as "fellow Twitter workers," the hackers lowered the victim's guard instantly.

WHY DID THE VICTIM COMPLY? The fake login link looked exactly like the page they see every single day, and so they didn't think to look closely at the URL to see it was fake.

CASE 5: THE UBER MFA FATIGUE ATTACK(2022)

The attackers purchased login credentials of an Uber worker from the dark web but Uber had **MFA (Multi-Factor Authentication)** turned on. This means every time the hacker tried to log in, a notification popped up on the worker's phone asking: *"Is this you trying to log in? Click Yes or No."* The hacker continuously sent hundreds of login requests to the worker's phone, one after the other for over an hour and finally contacting the worker directly with an official-looking request via WhatsApp. The WhatsApp message appeared as though it originated from the Uber IT team. The victim was told they needed to accept the MFA requests in order to make the requests stop. As the victim complied, the hacker was authenticated and they performed Lateral Movement, accessed Uber's internal Slack channels, found secret keys to their cloud servers (AWS and Google Cloud), and basically took over Uber's backend systems.

WHAT MADE THE ATTACKER CREDIBLE: If the worker just got notifications, they might have reported it. But by sending a WhatsApp message right at the same time, it made the system error look like an official IT plan.

WHY DID THE VICTIM COMPLY: When a human is hit with too much stress, their ability to make good choices drops to zero. The worker clicked "Yes" just to make the irritation stop.

QUICK RECOMMENDATIONS FOR DATAFINGERS:

- Never reset a password just because someone sounds stressed or helpful on a call. Always verify identity.
- If a boss asks for an urgent money transfer or password via video or text, call them back directly on their known personal line to confirm.
- Teach staff to pause for 60 seconds whenever an email or call makes them feel **extremely** rushed, scared, or overly curious.

REFERENCES & SOURCE MATERIAL:

Official sources to prove this report is backed by real-world data:

1. **MGM Resorts (2023):** University of Hawai'i West O-ahu
2. **RSA Security (2011):** Anatomy of a Spear-phishing attack by *Wired Magazine*.
3. **Hong Kong Deepfake (2024):** Case File from *Cyber Security Crime Bureau, HK Police*.
4. **Twitter VIP Hack (2020):** Official Regulatory Report by *New York DFS*.
5. **Uber Incident (2022):** Security Analysis by the *Cyber Safety Review Board (CSRB)*.